CIS Cisco Wireless LAN Controller 7 Benchmark [imported]

v1.1.0 - 12-04-2023

Terms of Use

Please see the below link for our current terms of use:

https://www.cisecurity.org/cis-securesuite/cis-securesuite-membership-terms-of-use/

ARCHIVE

Table of Contents

Terms of Use *1*
Table of Contents *2*
Overview *4*
Intended Audience 4
Consensus Guidance 5
Typographical Conventions 6
Recommendation Definitions *7*
Title 7
Assessment Status 7
Automated 7
Manual 7
Profile 7
Description 7
Rationale Statement 7
Impact Statement 8
Audit Procedure 8
Remediation Procedure 8
Default Value 8
References 8
CIS Critical Security Controls® (CIS Controls®) 8
Additional Information 8
Profile Definitions 9
Acknowledgements 10
Recommendations *11*
Appendix: Summary Table *45*
Appendix: CIS Controls v7 IG 1 Mapped Recommendations ..... *Error! Bookmark not defined.*
Appendix: CIS Controls v7 IG 2 Mapped Recommendations ..... *Error! Bookmark not defined.*
Appendix: CIS Controls v7 IG 3 Mapped Recommendations ..... *Error! Bookmark not defined.*
Appendix: CIS Controls v7 Unmapped Recommendations ..... *Error! Bookmark not defined.*

ARCHIVE

Appendix: CIS Controls v8 IG 1 Mapped Recommendations..... *Error! Bookmark not defined.*

Appendix: CIS Controls v8 IG 2 Mapped Recommendations..... *Error! Bookmark not defined.*

Appendix: CIS Controls v8 IG 3 Mapped Recommendations..... *Error! Bookmark not defined.*

Appendix: CIS Controls v8 Unmapped Recommendations..... *Error! Bookmark not defined.*

Appendix: Change History 47

ARCHIVE

Overview

All CIS Benchmarks focus on technical configuration settings used to maintain and/or increase the security of the addressed technology, and they should be used in **conjunction** with other essential cyber hygiene tasks like:

- Monitoring the base operating system for vulnerabilities and quickly updating with the latest security patches
- Monitoring applications and libraries for vulnerabilities and quickly updating with the latest security patches

In the end, the CIS Benchmarks are designed as a key **component** of a comprehensive cybersecurity program.

This document, Security Configuration Benchmark for Cisco Wireless LAN Controllers, provides prescriptive guidance for establishing a secure configuration posture for Cisco Wireless LAN Controller firmware version 7.2. This guide was tested against Cisco Wireless LAN Controller firmware v7.2.103.0. To obtain the latest version of this guide, please visit http://benchmarks.cisecurity.org. If you have questions, comments, or have identified ways to improve this guide, please write us at feedback@cisecurity.org.

Intended Audience

This benchmark is intended for system and application administrators, security specialists, auditors, help desk, and platform deployment personnel who plan to develop, deploy, assess, or secure solutions that incorporate Cisco IOS on a Cisco routing and switching platforms.

ARCHIVE

Consensus Guidance

This CIS Benchmark was created using a consensus review process comprised of a global community of subject matter experts. The process combines real world experience with data-based information to create technology specific guidance to assist users to secure their environments. Consensus participants provide perspective from a diverse set of backgrounds including consulting, software development, audit and compliance, security research, operations, government, and legal.

Each CIS Benchmark undergoes two phases of consensus review. The first phase occurs during initial Benchmark development. During this phase, subject matter experts convene to discuss, create, and test working drafts of the Benchmark. This discussion occurs until consensus has been reached on Benchmark recommendations. The second phase begins after the Benchmark has been published. During this phase, all feedback provided by the Internet community is reviewed by the consensus team for incorporation in the Benchmark. If you are interested in participating in the consensus process, please visit https://workbench.cisecurity.org/.

ARCHIVE

Typographical Conventions

The following typographical conventions are used throughout this guide:

Convention	Meaning
`Stylized Monospace font`	Used for blocks of code, command, and script examples. Text should be interpreted exactly as presented.
`Monospace font`	Used for inline code, commands, or examples. Text should be interpreted exactly as presented.
<italic font in brackets>	Italic texts set in angle brackets denote a variable requiring substitution for a real value.
Italic font	Used to denote the title of a book, article, or other publication.
Note	Additional information or caveats

ARCHIVE

Recommendation Definitions

The following defines the various components included in a CIS recommendation as applicable. If any of the components are not applicable it will be noted or the component will not be included in the recommendation.

Title

Concise description for the recommendation's intended configuration.

Assessment Status

An assessment status is included for every recommendation. The assessment status indicates whether the given recommendation can be automated or requires manual steps to implement. Both statuses are equally important and are determined and supported as defined below:

Automated

Represents recommendations for which assessment of a technical control can be fully automated and validated to a pass/fail state. Recommendations will include the necessary information to implement automation.

Manual

Represents recommendations for which assessment of a technical control cannot be fully automated and requires all or some manual steps to validate that the configured state is set as expected. The expected state can vary depending on the environment.

Profile

A collection of recommendations for securing a technology or a supporting platform. Most benchmarks include at least a Level 1 and Level 2 Profile. Level 2 extends Level 1 recommendations and is not a standalone profile. The Profile Definitions section in the benchmark provides the definitions as they pertain to the recommendations included for the technology.

Description

Detailed information pertaining to the setting with which the recommendation is concerned. In some cases, the description will include the recommended value.

Rationale Statement

Detailed reasoning for the recommendation to provide the user a clear and concise understanding on the importance of the recommendation.

ARCHIVE

Impact Statement

Any security, functionality, or operational consequences that can result from following the recommendation.

Audit Procedure

Systematic instructions for determining if the target system complies with the recommendation

Remediation Procedure

Systematic instructions for applying recommendations to the target system to bring it into compliance according to the recommendation.

Default Value

Default value for the given setting in this recommendation, if known. If not known, either not configured or not defined will be applied.

References

Additional documentation relative to the recommendation.

CIS Critical Security Controls® (CIS Controls®)

The mapping between a recommendation and the CIS Controls is organized by CIS Controls version, Safeguard, and Implementation Group (IG). The Benchmark in its entirety addresses the CIS Controls safeguards of (v7) “5.1 - Establish Secure Configurations” and (v8) '4.1 - Establish and Maintain a Secure Configuration Process” so individual recommendations will not be mapped to these safeguards.

Additional Information

Supplementary information that does not correspond to any other field but may be useful to the user.

ARCHIVE

Profile Definitions

The following configuration profiles are defined by this Benchmark:

- **Level 1**

  Items in this profile intend to:

  - be practical and prudent;
  - provide a clear security benefit; and
  - not negatively inhibit the utility of the technology beyond acceptable means.

- **Level 2**

  This profile extends the "Level 1" profile. Items in this profile exhibit one or more of the following characteristics:

  - are intended for environments or use cases where security is paramount.
  - acts as defense in depth measure.
  - may negatively inhibit the utility or performance of the technology.

ARCHIVE

Acknowledgements

This Benchmark exemplifies the great things a community of users, vendors, and subject matter experts can accomplish through consensus collaboration. The CIS community thanks the entire consensus team with special recognition to the following individuals who contributed greatly to the creation of this guide:

Author
Brian Sak

Contributor
Sergey Pavlov
Justin Opatrny
Rael Daruszka
Steven Piliero

ARCHIVE

Recommendations

1 Wireless LAN Controller

This section prescribes controls to secure wireless termination points and access controllers in a wireless system.

ARCHIVE

1.1 Install the Latest Firmware (Automated)

Profile Applicability:

- Level 1

Description:

The Wireless LAN Controllers should be upgraded to the latest firmware to resolve any discovered security vulnerabilities.

Rationale:

Wireless LAN Controllers running firmware with documented vulnerabilities could be subject to attacks including ones that may allow for unauthorized configuration changes or denial of service.

Audit:

Validate that the running Product Version is the same as the latest released version.
1. Run the following command to display the running Product Version:

```
(Cisco Controller) ><strong>show sysinfo</strong>
```

2. Compare the Product Version to the latest version on Cisco's website.

Remediation:

Download the latest firmware from the Cisco Website and apply it to the Wireless LAN Controller.

References:

1. http://www.cisco.com/en/US/docs/wireless/controller/7.0/command/reference/cli70commands.html#wp1320208

Additional Information:

PCI DSS §2.11 §4.2

ARCHIVE

1.2 Ensure 'Password Strength' is Strong for configured 'User Names' (Automated)

Profile Applicability:

- Level 1

Description:

This control determines if local administrative passwords meet minimum complexity requirements and are determined as "strong" by the Wireless LAN Controller. To meet the "strong" requirement the selected password must meet the following criteria:

- It is at least eight characters long.
- It contains a combination of upper- and lowercase letters, numbers, and symbols.
- It is not a word in any language.

Rationale:

Password complexity for administrative accounts reduces the risk of an attacker guessing the password. An attacker could gain unauthorized access to the Wireless LAN Controller by guessing a weak password.

Audit:

1. Perform the following to determine if the local management users are configured to use strong passwords.

```
(Cisco Controller) ><strong>show mgmtuser </strong>
```

2. Verify returned users have **Strong** listed in the Password Strength column.

```
User Name            Permissions      Description     Password Strength
------------------   --------------   --------------  ------------------
<Username>           read-write                       <strong>Strong</strong>
```

Note: Cisco bug (CSCuc22601) may cause **show mgmtuser** to show only User Name and Permissions, but not Description and not Password Strength.

Remediation:

Change the management user's password to one that meets the strong password requirements. The Wireless LAN Controller determines a password is strong if it meets the following requirements:

- It is at least eight characters long.
- It contains a combination of upper- and lowercase letters, numbers, and symbols.
- It is not a word in any language.

ARCHIVE

The new password can be applied using:

```
 (Cisco Controller) ><strong>config mgmtuser password</strong> <username>
<password>
```

Additional Information:

PCI DSS § 8.5.10.a §4.2

ARCHIVE

1.3 Delete the 'User Name' admin (Automated)

Profile Applicability:

- Level 1

Description:

This control determines if the default system usernames and passwords have been removed. The recommended setting is to delete admin (default account).

Rationale:

Default usernames and passwords are known to attackers and could allow unauthorized administrative access or to change the configuration of Access Points and/or the Wireless LAN Controller. The default is username is admin with a default password of admin.

Audit:

1. Perform the following to determine the local management users configured on the Access Controller.

```
 (Cisco Controller) ><strong>show mgmtuser</strong>
```

2. Verify the return value **does not** include the default User Name **admin**.

```
User Name                  Permissions    Description            Password
Strength
-----------------------    ------------   ---------------------  -------------
-----
<User Name>                 read-write                            Strong
```

Remediation:

New management users can be configured using the following command.

```
 (Cisco Controller) <strong>>config mgmtuser add</strong> <username>
<password> <privilege level>
```

After the creation of a new administrative username with the appropriate privileges the default one can be removed.

```
 (Cisco Controller) ><strong>config mgmtuser delete admin</strong>
```

References:

1. http://www.cisco.com/en/US/docs/wireless/controller/7.0/command/reference/cli70commands.html#wp7649595

ARCHIVE

Additional Information:

PCI DSS § 2.1.1.c § 4.2

PCI DSS Wireless Guidelines - Section 4.2 - Change Default Settings and Securely Configure Wireless Devices

PCI DSS Requirement - Section 2.1.1 - For wireless environments connected to the cardholder data environment or transmitting cardholder data, change wireless vendor defaults, including but not limited to default wireless encryption keys, passwords, and SNMP community strings.

ARCHIVE

1.4 Ensure 'Telnet' is disabled (Automated)

Profile Applicability:

- Level 1

Description:

This control determines whether the device allows administration via the telnet protocol. The recommended setting is telnet disabled.

Rationale:

Administrative access to the controller should be allowed only using cryptographically secure access methods. Unsecured administrative access methods, such as telnet, do not encrypt traffic between the client and the administrative interface. This could allow for interception or manipulation of the administrative session or capture of administrative credentials.

Audit:

Perform the following to determine if telnet is enabled.
1. Run the command below:

```
(Cisco Controller) ><strong>show network summary</strong>
```

2. Ensure telnet is disabled.

```
Telnet..................................... Disable
```

Remediation:

1. Disable command-line administration through telnet.

```
(Cisco Controller) ><strong>config network telnet disable</strong>
```

2. Enable command-line administration through Secure Shell Version 2 (SSHv2).

```
(Cisco Controller) ><strong>config network ssh enable </strong>
```

References:

1. http://www.cisco.com/en/US/docs/wireless/controller/7.0/command/reference/cli70commands.html#wp1319452

Additional Information:

PCI DSS §1.1.1 §4.2.1.e

ARCHIVE

PCI DSS Wireless Guidelines - Section 4.2.1 - Change Default Settings and Securely Configure Wireless Devices - Network Protocols and Identifiers

PCI DSS Requirement - Section 2.1.1 - For wireless environments connected to the cardholder data environment or transmitting cardholder data, change wireless vendor defaults, including but not limited to default wireless encryption keys, passwords, and SNMP community strings.

ARCHIVE

1.5 Ensure 'Webmode' is disabled (Automated)

Profile Applicability:

- Level 1

Description:

This control determines whether the device allows administration via webmode. The recommended setting is network webmode disabled.

Rationale:

Administrative access to the controller should only be allowed using cryptographically secure access methods. Unsecured administrative access methods, such as Hypertext Transfer Protocol (HTTP), do not encrypt traffic between the client and the administrative interface. This could allow for interception or manipulation of the administrative session or capturing administrative credentials. Enable Secure Shell Version 2 (SSHv2) or Hypertext Transfer Protocol Secure (HTTPS) for administration. The default setting is enabled.

Audit:

Perform the following to determine if telnet is enabled.
1. Run the command below:

```
 (Cisco Controller) ><strong>show network summary</strong>
```

2. Validate that webmode is disabled.

```
Webmode..................................... Disable
```

Remediation:

1. Disable administration through webmode.

```
 (Cisco Controller) ><strong>config network webmode disable
</strong>
```

References:

1. http://www.cisco.com/en/US/docs/wireless/controller/7.0/command/reference/cli70commands.html#wp1319452

Additional Information:

PCI DSS §1.1.1 §4.2.1.e

ARCHIVE

PCI DSS Wireless Guidelines - Section 4.2.1 - Change Default Settings and Securely Configure Wireless Devices - Network Protocols and Identifiers

PCI DSS Requirement - Section 2.1.1 - For wireless environments connected to the cardholder data environment or transmitting cardholder data, change wireless vendor defaults, including but not limited to default wireless encryption keys, passwords, and SNMP community strings.

ARCHIVE

1.6 Disable 'Management via Wireless Interface' (Automated)

Profile Applicability:

- Level 1

Description:

This control determines whether wireless clients can manage only the Cisco wireless LAN controller associated with the client and the associated Cisco lightweight access point. That is, clients cannot manage another Cisco wireless LAN controller with which they are not associated. The recommended setting is network mgmt-via-wireless disabled.

Rationale:

Administrative access should not be allowed from wireless clients because the wireless client is mobile; it can be stolen, misplaced, or lent to an unauthorized user. Allowing administrative access from the wireless network increases the possibility of an attacker gaining access to the admin interface. The default setting for mgmt-via-wireless is enabled.

Audit:

Perform the following to determine if administrative access is allowed from wireless clients.
1. Run the command below:

```
(Cisco Controller) ><strong>show network summary</strong>
```

2. Validate that Mgmt Via Wireless Interface is set to disable.

```
Mgmt Via Wireless Interface................. Disable
```

Remediation:

Disable access to the admin interface from wireless clients using the following command.

```
(Cisco Controller) ><strong>config network mgmt-via-wireless disable</strong>
```

References:

1. http://www.cisco.com/en/US/docs/wireless/controller/7.0/command/reference/cli70commands.html#wp1324232

Additional Information:

PCI DSS §2.3 §4.1

ARCHIVE

1.7 Ensure the 'CLI Login Timeout (minutes)' is less than or equal to 5 (Automated)

Profile Applicability:

- Level 2

Description:

This control determines how long a command-line session will stay idle before it is logged out. The recommended setting is 5 minutes or less, but not set to zero.

Rationale:

Command-line sessions timeout after a period of inactivity to reduce the risk of an unauthorized individual taking over an unattended, authenticated session. Validate that the inactivity timeout for CLI session's has not been set for more than the default or disabled altogether. The default inactivity timeout is 5 minutes.

Audit:

Validate the currently configured inactivity timeout.
1. Run the following command:

```
(Cisco Controller) ><strong>show sessions</strong>
```

2. Validate the timeout value is set to 5 minutes or less, but not 0. Zero indicates that timeout is disabled.

```
 CLI Login Timeout (minutes)........... 5
```

Remediation:

Reset the default authentication timeout value to 5 minutes.

```
(Cisco Controller) ><strong>config sessions timeout 5</strong>
```

References:

1. http://www.cisco.com/en/US/docs/wireless/controller/7.0/command/reference/cli70commands.html#wp1319842

ARCHIVE

1.8 Ensure 'SNMP v1 Mode' is disabled (Automated)

Profile Applicability:

- Level 1

Description:

This control determines whether or not Simple Network Management Protocol Version 1 (SNMP v1) can be used for remote network management. The recommended setting is disabled.

Rationale:

Simple Network Management Protocol Version 1 (SNMPv1) is not encrypted and is authenticated using a shared password. Encryption thwarts eavesdropping and attempts to manipulate network management protocols.

Audit:

Perform the following to determine which versions of Simple Network Management Protocol are enabled on the Wireless LAN Controller.
1. Run the following command:

```
(Cisco Controller) ><strong>show snmpversion</strong>
```

2. Ensure SNMP v1 Mode is set to **Disable**.

```
SNMP v1 Mode..................................... Disable
```

Remediation:

Disable SNMP version v1

```
(Cisco Controller) ><strong>config snmp version v1 disable</strong>
```

References:

1. http://www.cisco.com/en/US/docs/wireless/controller/7.0/command/reference/cli70commands.html#wp1319918

Additional Information:

PCI DSS §10.2 §4.2

PCI DSS Wireless Guidelines - Section 4.2.1 - Change Default Settings and Securely Configure Wireless Devices - Network Protocols and Identifiers

ARCHIVE

PCI DSS Requirement - Section 2.1.1 - For wireless environments connected to the cardholder data environment or transmitting cardholder data, change wireless vendor defaults, including but not limited to default wireless encryption keys, passwords, and SNMP community strings.

ARCHIVE

1.9 Ensure 'SNMP v2c Mode' is disabled (Automated)

Profile Applicability:

- Level 1

Description:

This control determines whether Simple Network Management Protocol version 2c (SNMP v2) can be used for remote network management. The recommended setting is disabled.

Rationale:

Simple Network Management Protocol Version 2c is not encrypted and is authenticated using a shared password. Encryption thwarts eavesdropping and attempts to manipulate network management protocols.

Audit:

Perform the following to determine which versions of SNMP are enabled on the Wireless LAN Controller.
1. Run the following command:

```
(Cisco Controller) ><strong>show snmpversion</strong>
```

2. Ensure that SNMP v2c Mode is set to **Disable**.

```
SNMP v2c Mode..................................... Disable
```

Remediation:

Disable SNMP version v2c

```
(Cisco Controller) ><strong>config snmp version v2c disable</strong>
```

References:

1. http://www.cisco.com/en/US/docs/wireless/controller/7.0/command/reference/cli70commands.html#wp1319918

Additional Information:

PCI DSS §10.2 §4.2

PCI DSS Wireless Guidelines - Section 4.2.1 - Change Default Settings and Securely Configure Wireless Devices - Network Protocols and Identifiers

ARCHIVE

PCI DSS Requirement - Section 2.1.1 - For wireless environments connected to the cardholder data environment or transmitting cardholder data, change wireless vendor defaults, including but not limited to default wireless encryption keys, passwords, and SNMP community strings.

ARCHIVE

1.10 Delete the 'SNMP v3 User Name' default (Automated)

Profile Applicability:

- Level 1

Description:

This control determines whether the `default` Simple Network Management Protocol Version 3 (SNMPv3) username included in the default configuration has been removed. The recommended setting is to delete the SNMP v3 User Name `default`.

Rationale:

Default username and password combinations are known to attackers and could be used to gain unauthorized access to the Wireless LAN Controller. SNMPv3 is disabled by default, however if enabled could allow unauthorized configuration changes using the default user.

Audit:

Validate that the default Simple Network Management Protocol Version 3 user **does not** exist.
1. Run the following command:

```
(Cisco Controller) ><strong>show snmpv3user</strong>
```

Ensure `default` is not present for SNMP v3 User Name.

```
SNMP v3 User Name      AccessMode    Authentication   Encryption
--------------------   -----------   --------------   ----------
<strong>default </strong>              Read/Write    HMAC-SHA         CFB-AES
```

Remediation:

Delete the default Simple Network Management Protocol Version 3 user.

```
(Cisco Controller) ><strong>config snmp v3user delete<span style="color:
black;"> default</span></strong>
```

If Simple Network Management Protocol Version 3 is to be used for network management, create a new Simple Network Management Protocol Version 3 user:

ARCHIVE

```
(Cisco Controller) ><strong>config snmp v3user create</strong> <username>
<ro/rw> <authentication type> <encryption type> <authentication key>
<encryption key>
```

References:

1. http://www.cisco.com/en/US/docs/wireless/controller/7.0/command/reference/cli70commands.html#wp1319901

ARCHIVE

1.11 Configure 'an authorized IP Address' for 'Logging Syslog Host' (Automated)

Profile Applicability:

- Level 1

Description:

This control determines if the Wireless LAN Controller is configured to send logging information to a centralized syslog server for processing and alerting. The recommended setting is to configure an authorized IP address for logging syslog.

Rationale:

Logging should be enabled on Wireless Termination Points and Access Controllers to detect access attempts, configuration changes, and system level events. Logs should be centrally collected and reviewed on a regular basis. It is recommended that logging is enabled on all devices and archived for a minimum of 12 months with 90 days of logs to be immediately available. Logging of wireless activity and administrative access is essential to detect anomalies and attacks on and from the wireless network.

Audit:

Validate that logging is enabled and a syslog host is defined. This can be done using one of two methods.
Method 1
1. Run the command below:

```
(Cisco Controller) ><strong>show logging</strong>
```

2. Verify that a syslog server is defined under the "Logging to syslog:" section.

```
 Logging to syslog :
- Number of remote syslog hosts..................... 1
  - Host 0..................................... <IP Address>
```

Method 2
1. Show the running configuration to the screen using the following command:

```
 (Cisco Controller) >s<strong>how run-config commands</strong>
```

2. Validate the return pattern matches:

```
 logging syslog host <IP Address>
```

Remediation:

To enable external logging to a syslog server execute the following command:

ARCHIVE

```
(Cisco Controller) ><strong>config logging syslog host </strong><IP Address>
```

References:

1. http://www.cisco.com/en/US/docs/wireless/controller/7.0/command/reference/cli70commands.html#wp5110363

Additional Information:

PCI DSS §10.2.2 §4.3

PCI DSS Wireless Guidelines - Section 4.3 - Wireless Intrusion Prevention and Access Logging PCI DSS Requirement - Section 11.4 - Use intrusion-detection systems, and/or intrusion-prevention systems to monitor all traffic at the perimeter of the cardholder data environment as well as at critical points inside of the cardholder data environment, and alert personnel to suspected compromises. Keep all intrusion-detection and prevention engines, baselines, and signatures up-to-date.

ARCHIVE

1.12 Configure 'an authorized IP Address' for 'NTP Server' (Automated)

Profile Applicability:

- Level 2

Description:

This control determines if Network Time Protocol is configured to synchronize time from an authorized external time source to the Wireless LAN Controller.

Rationale:

Network Time Protocol is configured on the Wireless LAN Controller to synchronize the local time with an external time source. Consistent, accurate time is important for certificate validation, logging, and forensic analysis. Network Time Protocol is not configured by default.

Audit:

1. Perform the following to determine if NTP is enabled.

```
 (Cisco Controller) ><strong>show time</strong>
```

2. Verify an authorized NTP Server address is configured:

```
NTP Polling Interval.........................     86400

     Index     NTP Key Index      NTP Server                NTP Msg Auth
Status
    -------  ----------------------------------------------------------------
       1              0           <IP Address>              <Authentication
Status>
```

Remediation:

Configure an authorized IP address for time NTP Server.

```
(Cisco Controller) ><strong>config time ntp server</strong> <index> <IP
Address>
```

References:

1. http://www.cisco.com/en/US/docs/wireless/controller/7.0/command/reference/cli70commands.html#wp2505839

ARCHIVE

Additional Information:

PCI DSS Wireless Guidelines - Section 4.2.3 - Change Default Settings and Securely Configure Wireless Devices -

PCI DSS §10.4 §4.2

Recommendations

PCI DSS Requirement - Section 2.1.1 - For wireless environments connected to the cardholder data environment or transmitting cardholder data, change wireless vendor defaults, including but not limited to default wireless encryption keys, passwords, and SNMP community strings.

ARCHIVE

1.13 Ensure 'Signature Processing' is enabled (Automated)

Profile Applicability:

- Level 1

Description:

This control determines whether Intrusion Detection System (IDS) signature processing is enabled for all IDS signatures. The recommended setting is enabled.

Rationale:

Wireless Protection Policies are a basic set of signatures that can detect attacks on the wireless network or clients. The Wireless LAN Controller can monitor the RF spectrum and detect attackers attempting to compromise or manipulate wireless networks. The Wireless LAN Controller should be configured to detect rogue Access Points or attacks on the wireless infrastructure or wireless clients. By default Protection Policies are not enabled.

Audit:

To validate that Wireless Protection Signature Policy Processing is enabled,
1. Run the following command:

```
(Cisco Controller) ><strong>show wps summary</strong>
```

2. Check output to ensure that Signature Processing is enabled.

```
Signature Policy
 Signature Processing.......................... Enabled
```

Remediation:

Enable all Wireless Protection Policies.

```
(Cisco Controller) > <span class="content"><span style="color: black; font-
style: normal; font-weight: bold;">config wps signature enable</span></span>
```

References:

1. http://www.cisco.com/en/US/docs/wireless/controller/7.0/command/reference/cli70commands.html#wp6871472

Additional Information:

PCI DSS §11.1 §3.2

ARCHIVE

PCI DSS Wireless Guidelines - Section 4.3 - Wireless Intrusion Prevention and Access Logging

PCI DSS Requirement - Section 11.4 - Use intrusion-detection systems, and/or intrusion-prevention systems to monitor all traffic at the perimeter of the cardholder data environment as well as at critical points inside of the cardholder data environment, and alert personnel to suspected compromises. Keep all intrusion-detection and prevention engines, baselines, and signatures up-to-date.

ARCHIVE

1.14 Enable 'all' Policies for 'wps client-exclusion' (Automated)

Profile Applicability:

- Level 2

Description:

This control determines the client exclusion policies that are enforced when clients attempt to associate with the device:

- `802.11-assoc` excludes clients on the sixth 802.11 association attempt, after five consecutive failures,
- `802.11-auth` excludes clients on the sixth 802.11 authentication attempt, after five consecutive failures,
- `802.1x-auth` excludes clients on the sixth 802.11X authentication attempt, after five consecutive failures,
- `ip-theft` excludes clients if the IP address is already assigned to another device,
- `web-auth` excludes clients on the fourth web authentication attempt, after three consecutive failures,
- **all** excludes clients for all of the above reasons.

The recommended setting is all.

Rationale:

Client Exclusion Policies are a group of settings that can automatically restrict client access if the Wireless LAN Controller detects excessive authentication failures or the theft or reuse of IP addressing. Excessive authentication attempts could be an indication that a client is attempting to brute force entry onto the wireless network or executing a denial-of-service attack. The default setting is enabled.

Audit:

Validate the Client Exclusion Policies are enabled.
1. Execute the following command:

```
(Cisco Controller) ><strong>show wps summary</strong>
```

2. Validate the the output shows that all of the Client Exclusion Policies are set to **Enabled.**

ARCHIVE

```
Client Exclusion Policy
 Excessive 802.11-association failures..... Enabled
 Excessive 802.11-authentication failures....... Enabled
 Excessive 802.1x-authentication............... Enabled
 IP-theft...................................... Enabled
 Excessive Web authentication failure........... Enabled
```

Remediation:

Enable the Client Exclusion Policies:

```
(Cisco Controller) ><strong>config wps client-exclusion all </strong>
```

References:

1. http://www.cisco.com/en/US/docs/wireless/controller/7.0/command/reference/cli70commands.html#wp9541897

ARCHIVE

1.15 Ensure 'Rogue Location Discovery Protocol' is enabled (Automated)

Profile Applicability:

- Level 2

Description:

This control determines whether the device will generate an alarm only, or automatically contain a rogue access point that is advertising your network's service set identifier (SSID).

Rationale:

Rogue Access Points that do not require authentication or encryption could allow unauthorized or malicious users to connect to the network. Rogue Location Discovery Protocol can actively seek out these Rogue Access Points and alert administrators to their existence after validating that they are connected to the network. By default RLDP is not enabled.

Audit:

Validate that Rogue Location Discovery Protocol is enabled.
1. Execute the following command:

```
(Cisco Controller) ><strong>show rogue ap rldp summary</strong>
```

2. Validate the output shows that Rogue Location Discovery Protocol is set to **Enabled.**

```
Rogue Location Discovery Protocol............... Enabled
```

Remediation:

Enable the Rogue Location Discovery Protocol:

```
(Cisco Controller) ><strong>config rogue ap rldp enable {alarm-only | auto-
contain}</strong>
```

References:

1. http://www.cisco.com/en/US/docs/wireless/controller/7.0/command/reference/cli70commands.html#wp4999879

ARCHIVE

1.16 Ensure 'Control Path Rate Limiting' is enabled (Automated)

Profile Applicability:

- Level 1

Description:

This control determines whether the switch control path rate limiting feature is enabled. The recommended setting is enabled.

Rationale:

If the Wireless LAN Controller is not able to keep up with the volume of management traffic it is receiving, a denial-of-service condition could occur. When control plane policing is enabled this ensures that the CPU is not overwhelmed by management traffic. The default state is enabled.

Audit:

Perform the following to determine if control plane policing is enabled or disabled.
1. Run the following command:

```
(Cisco Controller) ><strong>show advanced rate</strong>
```

2. Verify the following output:

```
 Control Path Rate Limiting.......................  Enabled
```

Remediation:

Enable control plane policing on the controller.

```
(Cisco Controller) ><strong>config advanced rate enable </strong>
```

References:

1. http://www.cisco.com/en/US/docs/wireless/controller/7.0/command/reference/cli70commands.html#wp7209817

ARCHIVE

2 Wireless Local Area Network (LAN) Configurations

This section prescribes controls to secure Wireless Local Area Networks (LAN).

ARCHIVE

2.1 Ensure 'Broadcast SSID' is disabled (Automated)

Profile Applicability:

- Level 1

Description:

This control determines if the Wireless Local Area Networks (WLANs) Service Set Identifier (SSID) is broadcast. The recommended setting is disabled.

Rationale:

Though it doesn't prevent an attacker from detecting the network, disabling broadcast Service Set Identifiers (SSIDs) will prevent casual users from seeing it on client side network lists. Disabling broadcast SSID will also make the identification of wireless networks more difficult.

Audit:

To validate that broadcast SSIDs are disabled,
1. Run the following command;

```
(Cisco Controller) ><strong>show wlan</strong> <WLAN ID>
```

2. Check the output for the status of Broadcast SSID for each WLAN. This should be set to Disabled.

```
 Broadcast SSID.................................. Disabled
```

Remediation:

1. Determine the WLANs to which the change will be made:

```
 (Cisco Controller) ><strong>show wlan summary </strong>
```

2. Disable broadcast SSID on all WLANs using:

```
(Cisco Controller) ><strong>config wlan broadcast-ssid disable</strong> <WLAN
ID>
```

References:

1. http://www.cisco.com/en/US/docs/wireless/controller/7.0/command/reference/cli70commands.html#wp8366770

ARCHIVE

2.2 Ensure 'WPA2-Enterprise' is Enabled for configured 'Wireless LAN identifiers' (Automated)

Profile Applicability:

- Level 1

Description:

This control determines if configured Wireless Local Area Networks (WLANs) are configured to use Wi-Fi Protected Access 2 (WPA2) security protocol. The recommended setting is to enable WPA2 and 802.1x for configured Wireless LAN identifiers (WLAN IDs).

Rationale:

Alternative encryption and authentication methods for connecting wireless clients to the wireless network have drawbacks. WEP has been proven ineffective and methods using pre-shared keys could be defeated by rainbow tables. 802.11i provides authenticated access using 802.1x and EAPoL and encryption using AES-based encryption.

Audit:

1. Run the following command to display a list of WLAN IDs managed by the device:

```
 (Cisco Controller) ><strong>show wlan summary</strong>
```

2. Run the following command for each WLAN ID:

```
(Cisco Controller) ><strong>show wlan</strong> <WLAN ID>
```

3. Ensure WPA2 is enabled.

```
      WPA2 (RSN IE)............................ Enabled
         AES Cipher............................ Enabled
         802.1x................................ Enabled
```

Remediation:

Run the following command for each WLAN ID when WPA2 is not enabled.

```
<span style="color: #333333; text-align: left;">(Cisco Controller)
></span><strong>config wlan security wpa2 enable </strong><WLAN ID>
```

References:

1. http://www.cisco.com/en/US/docs/wireless/controller/7.0/command/reference/cli70commands.html#wp4891599

ARCHIVE

Additional Information:

PCI DSS §2.1.1 §4.2

PCI DSS Wireless Guidelines - Section 4.4 - Strong Wireless Authentication and Encryption

PCI DSS Requirement - Section 4.1.1 - Ensure wireless networks transmitting cardholder data or connected to the cardholder data environment, use industry best practices (for example, IEEE 802.11i) to implement strong encryption for authentication and transmission. Note: The use of WEP as a security control was prohibited as of 30 June 2010.

ARCHIVE

2.3 Ensure 'Peer-to-Peer Blocking Action' is set to 'Drop' for All 'Wireless LAN Identifiers' (Automated)

Profile Applicability:

- Level 1

Description:

This control determines whether the Wireless LAN Controller is configured to prevent clients connected to the same Wireless Local Area Controller from communicating with each other.

Rationale:

Wireless Client Isolation prevents wireless clients from communicating with each other over the RF. Packets that arrive on the wireless interface are forwarded only out the wired interface of an Access Point. One wireless client could potentially compromise another client sharing the same wireless network.

Audit:

1. Determine which WLANs will be audited:

```
(Cisco Controller) ><strong>show wlan summary</strong>
```

2. To validate if peer-to-peer blocking is enabled on a WLAN, run the following command:

```
(Cisco Controller) ><strong>show wlan</strong> <WLAN ID>
```

3. Validate that the Peer-to-Peer Blocking Action is set to either **Drop** or **Forward-Upstream**.

```
Peer-to-Peer Blocking Action..................... Drop
```

Remediation:

1. Determine which WLANs will be changed:

```
(Cisco Controller) ><strong>show wlan summary</strong>
```

2. Enable client isolation or Publicly Secure Packet Forwarding on WLANs:

ARCHIVE

```
 (Cisco Controller) ><strong>config wlan peer-blocking drop</strong> <WLAN
ID>
```

References:

1. http://www.cisco.com/en/US/docs/wireless/controller/7.0/command/reference/cli70commands.html#wp10562677

Additional Information:

PCI DSS §4.1.1 §4.4

ARCHIVE

Appendix: Summary Table

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1	**Wireless LAN Controller**		
1.1	Install the Latest Firmware (Automated)	☐	☐
1.2	Ensure 'Password Strength' is Strong for configured 'User Names' (Automated)	☐	☐
1.3	Delete the 'User Name' admin (Automated)	☐	☐
1.4	Ensure 'Telnet' is disabled (Automated)	☐	☐
1.5	Ensure 'Webmode' is disabled (Automated)	☐	☐
1.6	Disable 'Management via Wireless Interface' (Automated)	☐	☐
1.7	Ensure the 'CLI Login Timeout (minutes)' is less than or equal to 5 (Automated)	☐	☐
1.8	Ensure 'SNMP v1 Mode' is disabled (Automated)	☐	☐
1.9	Ensure 'SNMP v2c Mode' is disabled (Automated)	☐	☐
1.10	Delete the 'SNMP v3 User Name' default (Automated)	☐	☐
1.11	Configure 'an authorized IP Address' for 'Logging Syslog Host' (Automated)	☐	☐
1.12	Configure 'an authorized IP Address' for 'NTP Server' (Automated)	☐	☐
1.13	Ensure 'Signature Processing' is enabled (Automated)	☐	☐
1.14	Enable 'all' Policies for 'wps client-exclusion' (Automated)	☐	☐
1.15	Ensure 'Rogue Location Discovery Protocol' is enabled (Automated)	☐	☐

ARCHIVE

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.16	Ensure 'Control Path Rate Limiting' is enabled (Automated)	☐	☐
2	**Wireless Local Area Network (LAN) Configurations**		
2.1	Ensure 'Broadcast SSID' is disabled (Automated)	☐	☐
2.2	Ensure 'WPA2-Enterprise' is Enabled for configured 'Wireless LAN identifiers' (Automated)	☐	☐
2.3	Ensure 'Peer-to-Peer Blocking Action' is set to 'Drop' for All 'Wireless LAN Identifiers' (Automated)	☐	☐

ARCHIVE

Appendix: Change History

Date	Version	Changes for this version

ARCHIVE